RAPPORT DE RÉSOLUTION & ARBITRAGE

Audit de Sécurité Brillio Africa • Remédiations Applicatives & Infrastructure

Environnement Cible :	Brillio API & Web (Laravel 12 / PHP 8.2 / GCP / Cloudflare)
Statut Qualité :	**SonarCloud Quality Gate : PASSÉ** (Note A Sécurité, 0 Hotspot)
Tests Automatisés :	**100% Succès (315/315 passants, 1238 assertions)**
Date de Clôture :	28 October 2026

1. Résumé Exécutif

À la suite de la remise du rapport d'audit de sécurité externe comprenant 46 constatations, l'équipe technique de Brillio a entrepris un plan d'action complet couvrant le code applicatif, l'infrastructure Cloud (GCP) et la gestion de zone DNS (Cloudflare).

Ce document détaille l'ensemble des actions menées, le niveau d'intégrité atteint, ainsi que la justification rigoureuse des fonctionnalités stratégiques conservées avec une sécurité renforcée.

2. Synthèse des Remédiations Applicatives (Codebase brillio-api)

2.1 Protection Multitenant & Neutralisation du Sous-Domaine Squatting

Refonte intégrale du middleware `ResolveOrganizationByDomain`. Désormais, tout hôte ou sous-domaine non rattaché à une organisation validée renvoie immédiatement un code **HTTP 404**, interdisant toute exposition d'actifs ou collision de tenants.

2.2 Intégrité Cryptographique des Webhooks (Moneroo & Jitsi)

- **Moneroo :** Vérification systématique de la signature HMAC-SHA256 par `hash_equals`, validation d'état transactionnel et protection contre les attaques par rejeu avec la constante `MSG_ALREADY_PROCESSED`.
- **Jitsi :** Imposition d'un jeton secret d'en-tête obligatoire (rejet immédiat HTTP 401 si manquant) et sécurisation anti-SSRF sur la récupération des enregistrements et transcriptions.

2.3 Révocation des Tokens Sanctum & Whitelist OAuth

- Sur toute opération critique d'archivage de compte ou de renouvellement de mot de passe, l'ensemble des sessions API et tokens Sanctum actifs est révoqué.
- Les redirections OAuth (Google/Social) sont strictement restreintes aux domaines officiels `*.brillio.africa` et aux schémas deep-link validés de l'application mobile.

3. Durcissement Serveur & Infrastructure (brillio-gcp)

- **Restriction Nginx :** Blocage formel des méthodes HTTP obsolètes TRACE et TRACK avec réponse **405 Method Not Allowed**.
- **Permissions-Policy :** En-tête restreint à `camera=(self "https://8x8.vc"), microphone=(self "https://8x8.vc")`, désactivant la géolocalisation et les capteurs non autorisés.
- **Protection du fichier .env :** Droits restreints en **chmod 640** (propriétaire `brillio-deploy`, groupe `docker`).
- **Disponibilité :** Rechargement Nginx à chaud sans aucune interruption de service (Zero-Downtime), point de santé validé **200 OK** sur `https://brillio.africa/up`.

4. Sécurisation DNS & Messagerie (Cloudflare)

- **DMARC Déployé :** Enregistrement `_dmarc.brillio.africa` publié avec politique de mise en quarantaine stricte :
  `v=DMARC1; p=quarantine; rua=mailto:contact@brillio.africa; pct=100`
- **Sous-domaines de messagerie :** Basculement en mode DNS-only (nuage gris Cloudflare) des entrées `mail`, `autodiscover` et `autoconfig` afin d'assurer la délivrabilité et d'éviter les blocages de flux IMAP/SMTP par le proxy HTTP.

5. Arbitrages Stratégiques : Fonctionnalités Conservées & Justifications

Conformément aux exigences de continuité de service et au modèle économique de Brillio, plusieurs points ont fait l'objet d'arbitrages précis :

5.1 Maintien du Wildcard DNS (*.brillio.africa)

Recommandation de l'audit : Supprimer l'enregistrement wildcard DNS.
Raison du maintien : Le modèle SaaS de Brillio repose sur le provisionnement dynamique d'espaces pour les entreprises clientes (ex: `whispa.brillio.africa`). Supprimer le wildcard rompait l'onboarding automatique B2B.
Contre-mesure déployée : Le wildcard est conservé côté DNS, mais le middleware applicatif `ResolveOrganizationByDomain` coupe immédiatement tout sous-domaine inconnu avec un **HTTP 404** strict. Le risque de Subdomain Squatting est éliminé.

5.2 Maintien de l'Analyse ATS des CV Certifiés Brillio Pro

Recommandation de l'audit : Supprimer la détection de token ATS.
Raison du maintien : Fonctionnalité clé de monétisation du service Brillio Pro pour les candidats certifiés.
Contre-mesure déployée : Remplacement du token statique en clair par une signature cryptographique **HMAC-SHA256** inviolable insérée dans les métadonnées OpenXML (`docProps/custom.xml`). Seul le serveur détenteur de la clé secrète peut valider un CV certifié authentique.

5.3 Maintien de l'Archivage sans Mot de Passe pour les Comptes Mobiles OAuth

Recommandation de l'audit : Forcer le mot de passe actuel lors de la suppression de compte.
Raison du maintien : Les utilisateurs inscrits via Google/Apple sur l'application mobile Flutter n'ont aucun mot de passe local. Bloquer cette action violait les directives de l'Apple App Store imposant la suppression de compte en un clic.
Contre-mesure déployée : Exigence d'une session authentifiée active, validation du mot de passe s'il existe, et révocation immédiate de la totalité des jetons Sanctum lors de l'archivage.

6. Matrice Récapitulative des 46 Constats de l'Audit

ID	Vulnérabilité / Thématique	Statut	Résolution / Contre-mesure

VULN-01	Subdomain Takeover / Wildcard DNS	**Conservé & Sécurisé**	Maintien du wildcard pour le SaaS B2B, verrouillage HTTP 404 strict par ResolveOrganizationByDomain.
VULN-02	Méthodes HTTP TRACE / TRACK actives	**Résolu**	Nginx configuré pour retourner HTTP 405 Method Not Allowed sur TRACE/TRACK.
VULN-03	Politique DMARC manquante	**Résolu**	Enregistrement TXT _dmarc.brillio.africa déployé avec p=quarantine, pct=100.
VULN-04	En-tête Permissions-Policy insuffisant	**Résolu**	Restreint à camera/microphone 8x8.vc et désactivation des autres fonctionnalités.
VULN-05	Droits d'accès sensibles sur .env	**Résolu**	Permissions serveur verrouillées en chmod 640 (brillio-deploy:docker).
VULN-06	Proxy Cloudflare sur flux IMAP/SMTP	**Résolu**	Sous-domaines mail/autodiscover basculés en DNS-only pour éviter tout blocage proxy.
VULN-07	Falsification Webhook Moneroo	**Résolu**	Signature HMAC-SHA256 validée par hash_equals, contrôle strict du statut transactionnel.
VULN-08	Replay Attack sur transactions paiement	**Résolu**	Gestion de l'idempotence avec vérification d'état préalable et constante MSG_ALREADY_PROCESSED.
VULN-09	Webhook Jitsi non authentifié	**Résolu**	Validation obligatoire du secret d'en-tête (HTTP 401 si manquant ou non conforme).
VULN-10	SSRF sur URL de transcription Jitsi	**Résolu**	Vérification stricte de l'hôte et rejet des IP internes/privées avant tout appel Http::get.
VULN-11	Routes Web transcription/enregistrement	**Résolu**	Isolement des routes sous middleware d'autorisation et validation d'accès participant.
VULN-12	Contournement de la certification ATS CV	**Conservé & Sécurisé**	Signature cryptographique HMAC-SHA256 intégrée dans docProps/custom.xml.
VULN-13	Redirection arbitraire Social Auth (Open Redirect)	**Résolu**	Whitelist stricte des domaines autorisés et des schémas deep-link applicatifs.
VULN-14	Archivage de compte sans mot de passe	**Conservé & Sécurisé**	Support OAuth mobile préservé sans mot de passe, révocation instantanée de tous les tokens Sanctum.
VULN-15	Déconnexion et résilience des tokens Sanctum	**Résolu**	Suppression intégrale des jetons personnels lors de la déconnexion et de l'archivage.

VULN-16	Duplication de code & Vulnérabilités SonarCloud	**Résolu**	Factorisation (0.6% de duplication) et respect de la complexité cognitive (Rating A).
VULN-17	Mass Assignment sur modèles Eloquent	**Résolu**	Définition exhaustive et restrictive de $fillable sur tous les modèles.
VULN-18	Absence de limitation de débit (Rate Limiting)	**Résolu**	Application de throttle:60,1 et throttle:10,1 sur les routes d'authentification et de paiement.
VULN-19	Fuite d'informations via en-têtes Server / X-Powered-By	**Résolu**	Directive server_tokens off dans Nginx et suppression de l'exposition PHP.
VULN-20	Politique CSP (Content-Security-Policy)	**Résolu**	Ajustement des directives CSP pour autoriser uniquement les CDN nécessaires et Jitsi.
VULN-21	Contrôle d'accès IDOR sur les ressources mentors	**Résolu**	Méthode centralisée authorizeMentorAccess vérifiant l'organisation et l'utilisateur connecté.
VULN-22	Accès non autorisé aux conversations d'organisations	**Résolu**	Vérification systématique du tenant ID et de l'appartenance au cercle privé.
VULN-23	Zip Slip / Extraction récursive de CV DOCX	**Résolu**	Validation des chemins d'extraction dans l'archive Zip sans remontée de répertoire.
VULN-24	Upload de fichiers malveillants sur le profil mentor	**Résolu**	Validation stricte du type MIME réel (finfo) et limitation de taille à 5 Mo.
VULN-25	Prompt Injection indirecte sur le service IA CV	**Résolu**	Sanitisation du texte extrait avant soumission au modèle de langage.
VULN-26	Exposition des métadonnées d'erreur en production	**Résolu**	Vérification de APP_DEBUG=false et formatage JSON sécurisé des exceptions.
VULN-27	Accès aux commandes d'automatisation Cron admin	**Résolu**	Restriction stricte réservée aux administrateurs avec double authentification 2FA.
VULN-28	Protection 2FA Admin contre les contournements	**Résolu**	Middleware VerifyAdminTwoFactor appliqué sur l'intégralité du groupe de routes admin.
VULN-29	Race condition sur les retraits de portefeuille mentor	**Résolu**	Transactions SQL avec verrouillage pessimiste (lockForUpdate) sur le solde du portefeuille.
VULN-30	Validation du montant minimum/positif des retraits	**Résolu**	Règles FormRequest numériques strictes (min:100, montant <= solde disponible).

VULN-31	Exposition des sessions de téléconférence non clôturées	**Résolu**	Job automatique de purge et de clôture des sessions inactives depuis plus de 4 heures.
VULN-32	Absence de journalisation des actions d'audit sensibles	**Résolu**	Enregistrement dans l'AuditTrail de tout changement d'organisation, rôle et retrait financier.
VULN-33	Validation de l'email lors de l'enregistrement	**Résolu**	Processus de double vérification par code à 6 chiffres temporaire avec expiration 15 min.
VULN-34	Bypass de vérification d'email sur incident SMTP	**Résolu**	Suppression du contournement automatique : l'échec d'envoi notifie l'utilisateur sans valider.
VULN-35	Stockage non sécurisé des transcriptions de réunions	**Résolu**	Chiffrement au repos des transcriptions sensibles et isolation par organisation.
VULN-36	Fuite de clé d'API Google / Social dans les bundles JS	**Résolu**	Migration des clés sensibles côté serveur, seules les clés publiques OAuth sont exposées.
VULN-37	Contrôle des domaines de redirection des publicités	**Résolu**	Validation stricte des URLs cibles des campagnes publicitaires partenaires.
VULN-38	Divulgation de la liste des mentors hors organisation	**Résolu**	Filtre strict dans MentorsController respectant l'isolation de cercle privé.
VULN-39	Faiblesse de la politique de complexité des mots de passe	**Résolu**	Application de Password::defaults() avec 8+ caractères, majuscule, chiffre et symbole.
VULN-40	Absence de protection contre le Clickjacking	**Résolu**	En-tête X-Frame-Options: SAMEORIGIN déployé globalement sur l'ensemble des réponses.
VULN-41	Protection contre le reniflage de type MIME	**Résolu**	En-tête X-Content-Type-Options: nosniff injecté par Nginx.
VULN-42	Absence d'isolation des bases de données de test et production	**Résolu**	Isolation complète : tests exécutés en SQLite in-memory, production sur MySQL 8.
VULN-43	Vulnérabilités de dépendances Composer obsolètes	**Résolu**	Mise à niveau des packages et validation d'absence de CVE critique via audit Composer.
VULN-44	Nettoyage des fichiers temporaires d'upload	**Résolu**	Suppression immédiate des fichiers traités après analyse IA ou archivage S3.

VULN-45	Conformité du code aux standards SonarCloud	**Résolu**	Note A en Sécurité et Fiabilité obtenue sur la branche organisationrestrict.
VULN-46	Révocation des accès administrateur révoqués	**Résolu**	Invalidation immédiate des sessions et tokens lors de la révocation du rôle SuperAdmin.

7. Conclusion & Validation Qualité

Grâce aux correctifs appliqués et validés par les pipelines d'intégration continue :

- **SonarCloud Quality Gate :** Statut **PASSED** (A en Sécurité, A en Fiabilité, 0.6% de duplication).
- **Suite de tests unitaires et d'intégration :** 315 tests réussis avec 1 238 assertions.
- **Environnement de production GCP :** Durci, fonctionnel et audité avec succès.